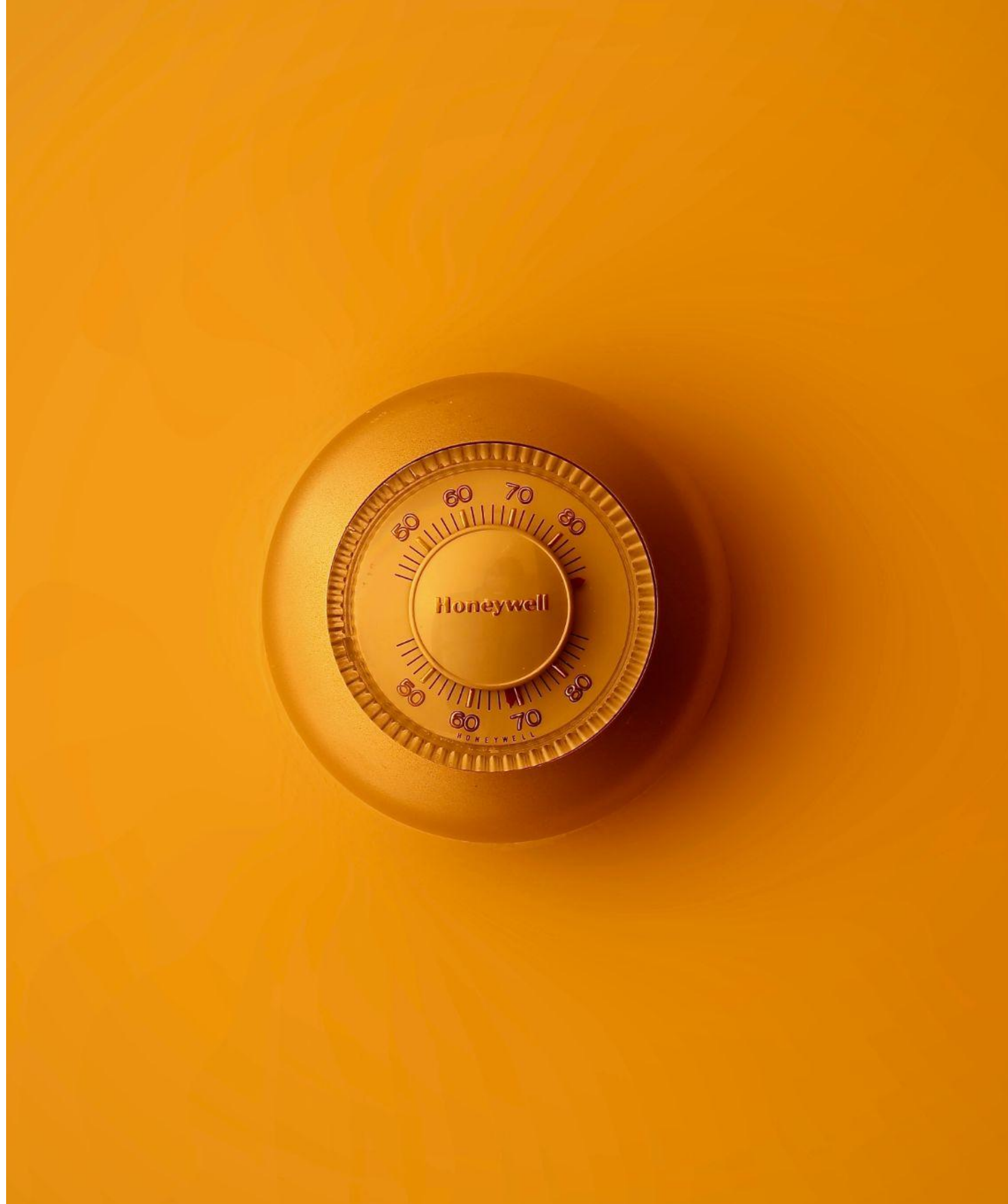


1. OVERVIEW

An overview of Requirement 9 (“Restrict Physical Access”), and its sub-requirements.



REQ. 9: RESTRICT PHYSICAL ACCESS

REQ. 9: RESTRICT PHYSICAL ACCESS **OVERVIEW**

Requirement 9 (Restrict Physical Access to Cardholder Data) is about protecting premises, people and physical media.

- It usually defines three different “layers”, which have different security controls - a facility, the entire CDE, and areas with sensitive data within the CDE - protected accordingly;

This requirement focuses mostly on:

- Establishing physical security controls (locked rooms, locked racks, CCTV, physical security, etc);
- Properly inventorying all devices with CHD, as well as their movements, creation, destruction and lifecycle, overall;
- Preventing tampering of devices containing CHD;

REQ. 9: RESTRICT PHYSICAL ACCESS **OVERVIEW**

The sub-requirements for this requirement include:

- 9.1 Processes and mechanisms for restricting physical access to cardholder data are defined and understood.
- 9.2 Physical access controls manage entry into facilities and systems containing cardholder data.
- 9.3 Physical access for personnel and visitors is authorized and managed.
- 9.4 Media with cardholder data is securely stored, accessed, distributed, and destroyed.
- 9.5 Point of interaction (POI) devices are protected from tampering and unauthorized substitution.





REQ. 9: RESTRICT PHYSICAL ACCESS

REQ. 9: RESTRICT PHYSICAL ACCESS **OVERVIEW**

9.1 Processes and mechanisms for restricting physical access to cardholder data are defined and understood

- The usual sub-requirement. All processes for protecting data physically must have accurate and enforced documentation. Same for roles and responsibilities;

This is usually tested through:

- Examining the process and policy documents;
- Interviewing personnel about the definition and enforcement of those processes and policies;

REQ. 9: RESTRICT PHYSICAL ACCESS

OVERVIEW

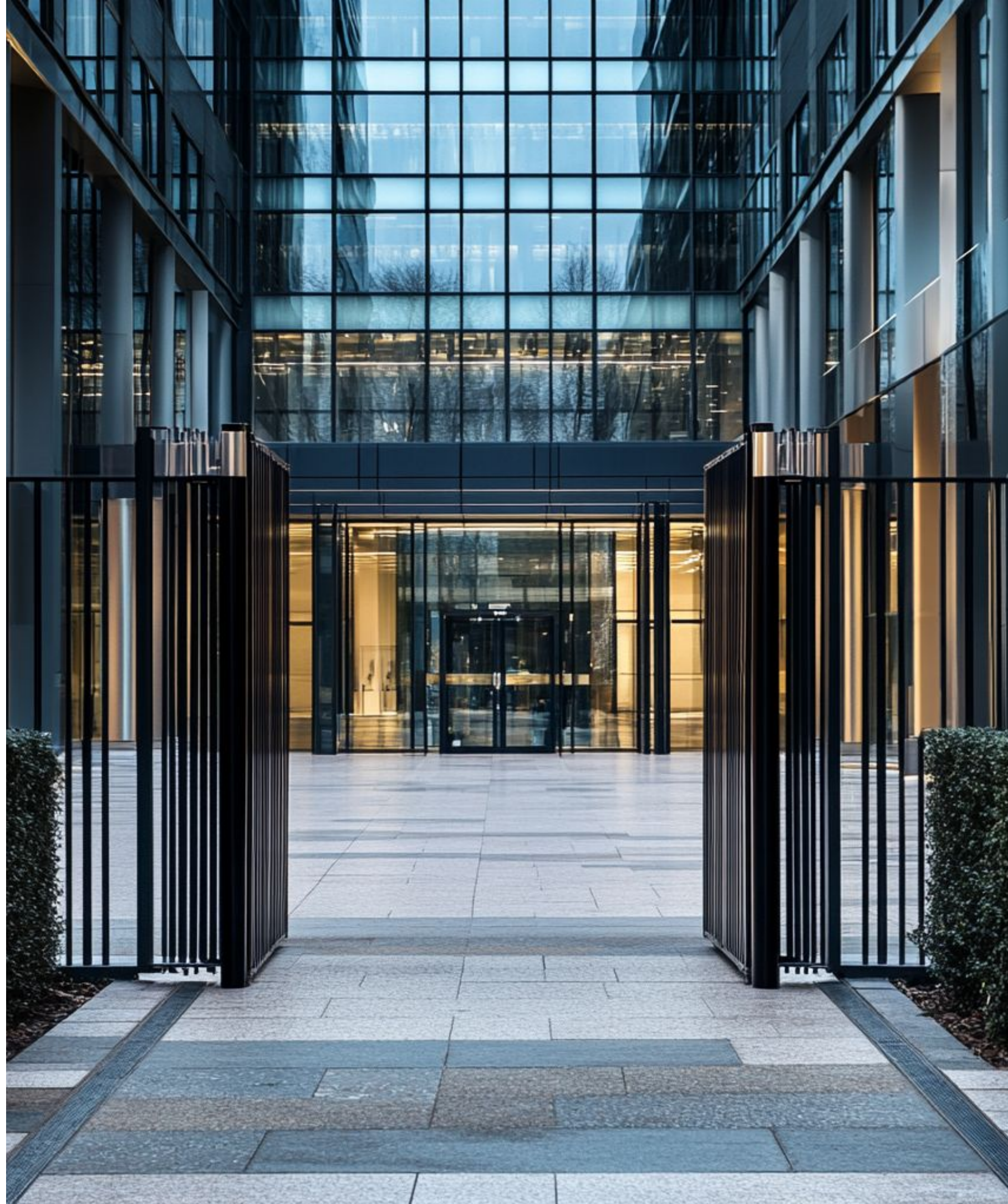
9.2 Physical access controls manage entry into facilities and systems containing cardholder data

- This sub-requirement has two areas of focus:
- One is protecting the entire CDE some sort of physical control. Security, locked doors... Then, for sensitive areas, video recording and user data collection are required (90d);
- Also, restricting open systems/ports. No open network jacks, no using internal wireless networks or equipment, consoles, etc;

This is usually tested through:

- Examining ingress/egress logs for various areas, including those with sensitive data;
- Interviewing personnel on the security controls used;





REQ. 9: RESTRICT PHYSICAL ACCESS

REQ. 9: RESTRICT PHYSICAL ACCESS **OVERVIEW**

9.3 Physical access for personnel and visitors is authorized and managed

- This sub-requirement focuses on properly managing the credentials of who accesses facilities;
- Visitors must be clearly identified, escorted at all times, and authorized. Badges must be surrendered/deactivated;
- There must be visitor logs with extensive information;
 - Name, organization, date/time, internal personnel;
- Changes to user access must go through processes;

This is usually tested through:

- Examining the processes for changing user access privileges, and visitation logs;
- Examining visitor logs, including information collected;

REQ. 9: RESTRICT PHYSICAL ACCESS

OVERVIEW

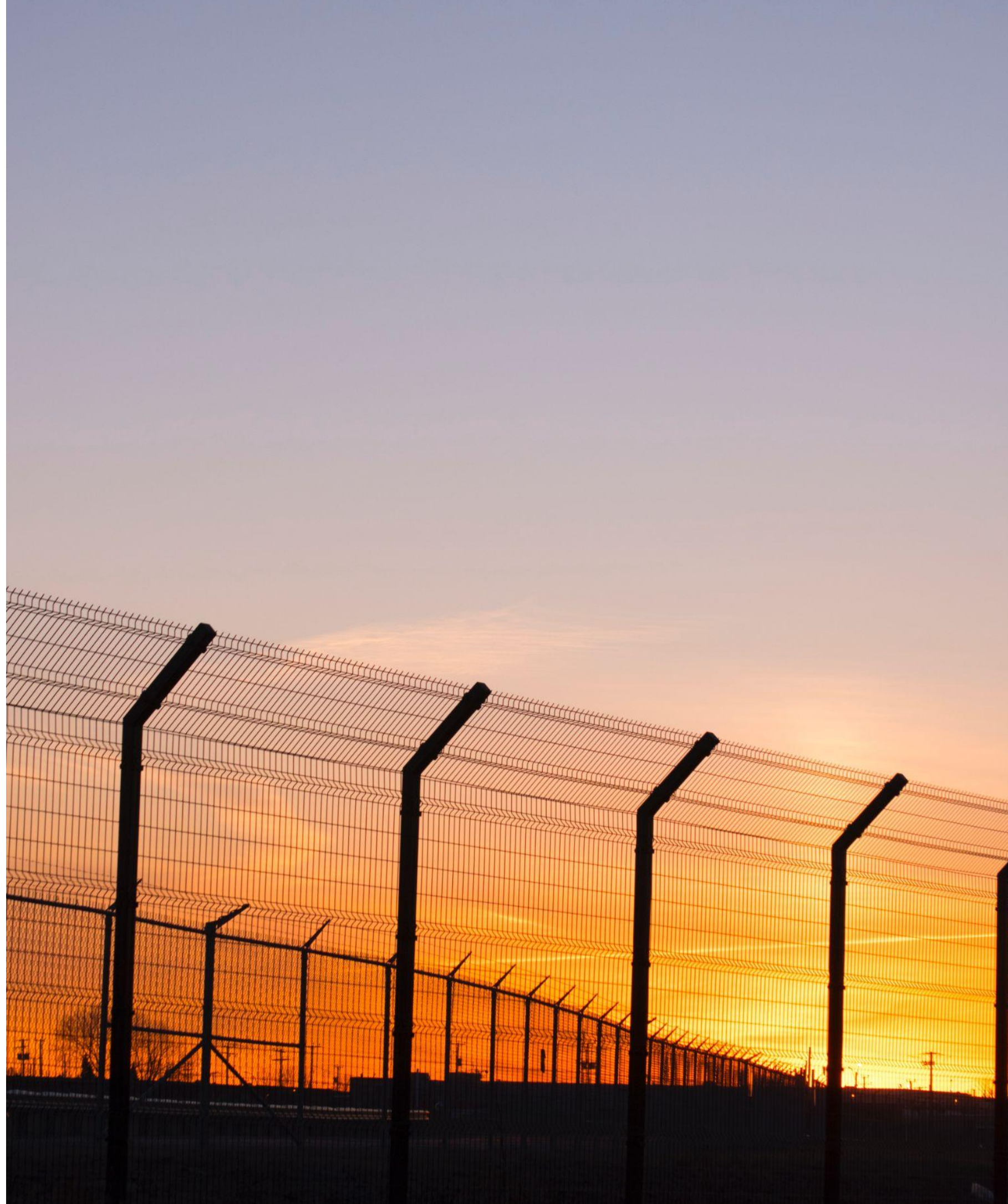
9.4 Media with cardholder data is securely stored, accessed, distributed, and destroyed

- All media that contain cardholder data must be inventoried (and reviewed yearly);
- Remember these not just HDDs! USBs, paper records, etc;
- We must log all movements of these media, and approve movements outside the organization (e.g. for repairs);
- These must be destroyed when not used anymore, and we need certificates of their destruction (shred, 0-erase, burn);

This is usually tested through:

- Examination of media inventories and logs of reviews;
- Examining documents and interviewing personnel to verify processes for moving and destroying media;





REQ. 9: RESTRICT PHYSICAL ACCESS

REQ. 9: RESTRICT PHYSICAL ACCESS **OVERVIEW**

9.5 Point of interaction (POI) devices are protected from tampering and unauthorized substitution

- We must keep an inventory of these systems (updated at all times), and must periodically check for tampering (such as a possible skimmer installed by someone). Personnel should be properly trained on how to perform this, too;

This is usually tested through:

- Examining POI inventories and the details within them, as well as logs of inventory reviews;
- Examining documentation and interviewing personnel regarding the verification of tampering in POIs, as well as the frequency with which it is performed;

REQ. 9: RESTRICT PHYSICAL ACCESS

OVERVIEW

How can we summarize, then, this requirement?

- Physical control must be strict. We must have controls for all CDE facilities, and added controls for facilities with sensitive data (e.g., rooms with CHD hard drives);
- Visitors in specific are of note. They must be distinguished from other users, clearly authorized, with data collected on them, and surrender their badges. There must be formal processes to change user access privileges;
- Media with CHD must be strictly controlled. Updated inventories, tracking of all movement, and tracking of their destruction with certificates;
- POI devices that capture card must be strictly inventoried, with no tampering occurring, and personnel trained for it;



REQ. 9: RESTRICT PHYSICAL ACCESS

OVERVIEW

EXAMPLES

/01 POS SKIMMING

The POS sub-req is mostly to prevent skimming, where the attacker installs an additional component to capture data. Staff training is crucial to detect it.

/02 THE EQUIVALENT OF 7

Requirement 7 was about need-to-know access of digital data. In a sense, this is the physical equivalent. Minimizing access based on roles and functions.

/03 PROVING IT WAS DONE

Destruction of both physical and digital media can be done by a myriad means. The important is that, at the end of the day, the provider certifies its destruction.

REQ. 9: RESTRICT PHYSICAL ACCESS

OVERVIEW

USE CASES

SMALL COFFEE SHOP

- The organization keeps any physical documents containing CHD, such as signed receipts or order forms, in locked drawers or cabinets;
- PoS terminal access is limited by positioning them in areas only accessible to employees, with clients only able to insert a card and press the keys;

E-COMMERCE STORE

- The organization restricts physical access to rooms housing servers and networking equipment that transmit CHD with locks, access cards, and biometric controls (2 of these factors required for entry);
- The organization installs CCTV cameras to monitor entry/exit points of secure areas, retaining 90d footage;

HOTEL CHAIN

- The organization uses mandatory keycards and biometrics to limit entry to data centers and IT rooms where CHD are stored or processed;
- The organization requires all staff to wear visible identification badges, and to challenge or report individuals that have missing/mismatching ID;

PAYMENT PROCESSOR

- The organization employs multiple layers of security at data centers, including security guards, CCTV, locked rooms and biometric auth to protect all areas with CHD;
- The organization enforces rigorous procedures for granting visitor access, including quick expiration, flashy color badges, etc;

REQ. 9: RESTRICT PHYSICAL ACCESS

OVERVIEW

KEY TAKEAWAYS

/01 RESTRICTING ACCESS

Requirement 9 is all about protecting our card data and systems in the real world, both by limiting actions by users, but also by securing our physical systems.

/03 9.2 STRICT PHYSICAL AC

There must be physical access controls for entry into facilities with CDE systems, and added controls for areas with sensitive information (video/user data).

/05 9.4 STRICT USE OF MEDIA

All media with CHD must be inventoried, annually reviewed, all movements must be approved and logged, and destruction performed with certificates.

/02 9.1 PROCESSES DEFINED

The usual sub-requirement. All process and policy documentation defined and in use, and the same for definitions of the associated roles and responsibilities.

/04 9.3 STRICT VISITATION

Visitors must be clearly identified, escorted, and be authorized by someone. There must be extensive logs. There must be procedures for changing physical AC.

/06 9.5 STRICT USE OF POI

We must know all the POI systems we have that capture card data, as well as prevent tampering, and have personnel trained to do this.